ICS/OT/IoT Threat Model

Schneider Electric EcoStruxure Panel Server PAS600 (Panel Server Universal gateway; variants PAS600, PAS600L, PAS600LWD; family PAS400/PAS800; firmware ref DOCA0172EN-20, observed FW 002.003.000 / 003.000.000)

Generated 2026-08-09 05:21:39 UTC - Model: anthropic / claude-opus-4-8

> Frameworks: MITRE EMB3D - MITRE ATT&CK for ICS - ISA/IEC 62443 (3-3, 4-2, 4-1, 2-1) - ISA-TR84.00.09 - Attify IoT. Identifiers marked * are model-supplied (not from the embedded reference set).

Executive Summary

The Schneider Electric PAS600 EcoStruxure Panel Server is a DIN-rail energy/data concentrator and protocol gateway that aggregates measurements from wireless (IEEE 802.15.4 / Zigbee PowerTag, HeatTag, Acti9 Active) and wired Modbus-SL (RS485) field devices and exposes them northbound over dual Ethernet (ETH1/ETH2), Wi-Fi, Bluetooth/BLE, Modbus TCP/IP (port 502), OPC UA, EtherNet/IP, SNMP, DPWS, HTTPS web UI, and SFTP/HTTPS cloud publication to EcoStruxure. Its attack surface is dominated by an unauthenticated-capable Modbus gateway (virtual server ID routing across subnets), a management web server with user accounts (Administrator/Viewer, default-password reset flow), multiple RF interfaces, a USB/DPKG configuration import-export path, and remotely-initiated firmware update (EPC/USB, .sps2/eIO images) - each a concrete EMB3D and ATT&CK-for-ICS concern. Key device weaknesses derive from Modbus lacking authentication/encryption (TID-406/407/408), potential default/weak credentials on the web UI (TID-311/314), certificate-validation and TLS configuration risks on OPC UA/HTTPS/cloud (TID-316/411), wireless key/join abuse on 802.15.4/Wi-Fi/BLE (TID-407/411/860), and firmware update integrity/rollback exposure (TID-211/213/216). Compromise of the gateway enables manipulation or spoofing of energy/telemetry (T0832/T0856), denial of view (T0815/T0829), pivoting between OT/IT subnets via its routing/forwarding capability (T0812*/TID-412), and use as a persistence/C2 foothold. The PAS600 is not itself a safety instrumented system, but as a monitoring/notification concentrator its manipulation can defeat operator situational awareness (alarm/notification suppression) that acts as a protection/administrative layer, so ISA-TR84.00.09 consequence analysis is included for loss-of-view and masked thermal (HeatTag) hazard scenarios. This model maps the device against EMB3D properties/threats/mitigations, ATT&CK for ICS TTPs, IEC 62443-4-2/-3-3/-4-1, the Attify IoT reverse-engineering surface, and provides a prioritized risk register plus the three required diagrams. All findings are grounded in the OCR-degraded DOCA0172EN-20 manual and published EcoStruxure Panel Server facts; unknowns (SoC, debug ports, exact crypto) are recorded as assumptions.

1. System Model

The PAS600 Panel Server is an embedded Linux-class gateway/concentrator. Southbound it collects data from IEEE 802.15.4 wireless devices (PowerTag energy sensors A9MEM series, HeatTag thermal sensors, Acti9 Active, TH110/CL110 ambient sensors) and from RS485 Modbus-SL meters/breakers (iEM3150/iEM3155, PM800/PM5563/PM8000, MasterPact MTZ). Northbound it exposes dual Ethernet (ETH1/ETH2 - switched or dual-subnet mode), Wi-Fi (infrastructure + access-point commissioning), Bluetooth/BLE, and USB-C. It acts as a Modbus TCP/IP gateway (port 502) using virtual server IDs to route requests to downstream Modbus addresses, and publishes data to EcoStruxure cloud or third-party servers via SFTP/HTTPS. Management is via an embedded HTTPS web server, EcoStruxure Power Commission (EPC) desktop/mobile, and DPWS discovery. Additional services observed: OPC UA server (certificate-based), EtherNet/IP, SNMP, SNTP/NTP time sync, DNS, RSTP, DHCP, 802.1X (cert-based), FTP/FTPS.

Components

Component	Role	Sub-components
Main Application Processor / SoC	Runs gateway firmware, web server, protocol stacks, cloud client	ARM-class CPU (assumed), DDR DRAM (PID-1241), SPI/NAND flash firmware storage, possible secure element / crypto for TLS (assumed)
Ethernet subsystem	Dual RJ45 ETH1/ETH2, 10/100, PoE (802.3af) capable; switched or dual-subnet routing	MAC/PHY, internal switch, RSTP ring support
IEEE 802.15.4 radio	Concentrator for wireless PowerTag/HeatTag/Acti9 sensors (up to ~150/1000 via routers)	802.15.4 transceiver, Zigbee-style network stack, join/pairing manager

Component	Role	Sub-components
Wi-Fi + Bluetooth radio	2.4GHz Wi-Fi (WPA/WPA2/802.11i) infra & AP commissioning; BLE mobile commissioning	Wi-Fi combo module, BLE GATT stack, AP mode
RS485 serial interface	Modbus-SL master to downstream meters/breakers (D1/+ D0/- terminals)	RS485 transceiver, Modbus RTU master stack
USB-C port	Local configuration, firmware update, config import/export (DPKG file)	USB device controller, file import/export handler
Embedded I/O	Digital/pulse inputs (Input 1/2), relay/digital outputs, alarm thresholds	input debounce/edge detection, output driver
Embedded web server + auth	Management UI, user/role management, certificate management	HTTPS server, session manager, Administrator/Viewer RBAC, self-signed/CA cert store
Cloud/publication client	Publishes measurements to EcoStruxure cloud / third-party via SFTP/HTTPS	TLS client, trust store, scheduler
Firmware update subsystem	Remote/USB firmware update of PAS600 and downstream wireless devices	EPC update client, .sps2/eIO image loader, version selection

Interfaces

Interface	Type	Protocol	Exposure
ETH1 / ETH2	network	Ethernet/IP, Modbus TCP (502), HTTPS, OPC UA, SNMP, DPWS, EtherNet/IP, RSTP, DHCP, DNS, SNTP, FTP/FTPS	external
Wi-Fi (infra + AP)	wireless	IEEE 802.11 b/g/n 2.4GHz, WPA/WPA2/802.11i, 802.1X	external
Bluetooth/BLE	wireless	BLE GATT (mobile commissioning)	physical
IEEE 802.15.4 radio	wireless	802.15.4 / Zigbee-style	external
RS485 serial	bus	Modbus RTU (Modbus-SL)	zone
USB-C	physical	USB config/firmware (DPKG, .sps2/eIO)	physical
Embedded web UI	api	HTTPS (HTTP redirect), REST	external
OPC UA server	api	OPC UA binary/TLS, certificate trust list	external
Cloud publication	network	SFTP / HTTPS to EcoStruxure	external
Debug/test port (UART/JTAG assumed)	debug	UART/JTAG/SWD (unconfirmed)	physical

Data Flows

From	To	Data	Protocol	Crosses boundary
PowerTag/HeatTag wireless sensors	PAS600 802.15.4 radio	energy/thermal telemetry	IEEE 802.15.4	Yes
Modbus-SL meters (iEM3155/PM8000)	PAS600 RS485	power/energy measurements	Modbus RTU	Yes
SCADA/HMI/Modbus master	PAS600 ETH (502)	Modbus read/write, virtual server ID routed	Modbus TCP	Yes
Engineer / EPC	PAS600 web UI / USB	config, firmware, credentials	HTTPS / USB	Yes
PAS600 cloud client	EcoStruxure cloud	measurement publication	SFTP/HTTPS	Yes
PAS600 ETH1	PAS600 ETH2 downstream subnet	routed/forwarded Modbus traffic	IP forwarding / Modbus gateway	Yes

From	To	Data	Protocol	Crosses boundary
OPC UA client (upstream app)	PAS600 OPC UA server	tags/measurements	OPC UA/TLS	Yes

2. Device Model - EMB3D Properties

Property	Category	Feature / Interface	Present	Notes
PID-11	Hardware	Main application SoC/microprocessor	Yes	Embedded processor runs Linux-class gateway firmware; exact part not legible in OCR (assumed).
PID-1241	Hardware	DDR DRAM	Yes	Runtime RAM holds session tokens, TLS keys, Modbus buffers.
PID-123	Hardware	SPI/NAND flash + USB removable config media	Yes	Firmware and DPKG config stored in NVM; USB-C accepts firmware/config files.
PID-14	Hardware	External peripheral interconnect (USB-C, RS485)	Yes	USB-C for config/firmware; RS485 terminals D1/D0.
PID-15	Hardware	Hardware access/debug port (UART/JTAG)	Yes	Not confirmed in OCR; assumed present on PCB (test pads).
PID-21	System Software	Bootloader	Yes	Boots signed firmware images (.sps2); secure-boot status unconfirmed.
PID-22	System Software	Debugging/diagnostic capabilities	Yes	System monitoring, logs, service status pages present.
PID-23	System Software	OS/kernel (embedded Linux assumed)	Yes	Runs multiple network services concurrently.
PID-23221	System Software	OS/web user accounts (Administrator/Viewer)	Yes	Role-based accounts, change/reset password flow.
PID-27	System Software	Firmware/software update support	Yes	Update via EPC and USB; downstream device firmware update too.
PID-272	System Software	Cryptographic firmware integrity mechanisms	Yes	Signed images assumed (.sps2); rollback protection unconfirmed.
PID-275	System Software	Remotely-initiated firmware updates	Yes	EPC/web-initiated update; possible DoS window (~10 min).
PID-28	System Software	System event logging	Yes	Logs and system monitoring pages; tamper/export protections unclear.
PID-311	Application Software	Embedded HTTPS web application	Yes	Management UI, cloud config, data sampling, settings.
PID-33	Application Software	Interactive services/UIs (web, OPC UA, EPC)	Yes	Multiple management/data services.
PID-331	Application Software	Unauthenticated services (Modbus TCP, DPWS, SNMP, discovery)	Yes	Modbus/502 and discovery typically unauthenticated.
PID-332	Application Software	Authenticated services (web UI, OPC UA, cloud)	Yes	Password and certificate based.
PID-3321	Application Software	Password authentication	Yes	Web login; default password reset flow referenced.
PID-3322	Application Software	Cryptographic user/session authentication	Yes	TLS sessions, 802.1X cert auth, OPC UA certs.
PID-41	Networking	Remote network services (Modbus TCP, OPC UA, HTTPS, SNMP, EtherNet/IP, DPWS, FTP)	Yes	Broad service exposure across ETH/Wi-Fi.

Property	Category	Feature / Interface	Present	Notes
PID-411	Networking	Remote config/sensitive modification services	Yes	Web UI + EPC modify credentials, network, publication, firmware.
PID-4111	Networking	Protocols lacking message authentication (Modbus, SNMP v1/v2c)	Yes	Modbus TCP/RTU has no native auth.
PID-4112	Networking	Protocols lacking encryption (Modbus, HTTP redirect, SNMP)	Yes	Modbus/SNMP cleartext; sensitive telemetry exposed.
PID-4113	Networking	Cryptographic functions (TLS, OPC UA, SFTP, 802.1X, certs)	Yes	Certificate management (self-signed/CA), TLS for HTTPS/cloud.
PID-42	Networking	Message forwarding/routing (Modbus gateway, ETH1/ETH2 IP forwarding)	Yes	Virtual server ID routing; OT/IT bridging risk.
PID-16	Hardware	Multiple radio interfaces (802.15.4, Wi-Fi, BLE)*	Yes	RF attack surface for join/pairing/replay.

3. EMB3D Threat -> Mitigation Table

Element	TID	Threat	Lik.	Imp.	Mitigations	Summary
Modbus TCP gateway (502) / RS485	TID-406	Unauthorized Messages or Connections	High	High	MID-034, MID-083, MID-080	Authenticate/authorize Modbus, restrict via ACL/firewall, rate-limit requests.
Modbus / SNMP / discovery traffic	TID-408	Unencrypted Sensitive Data Communication	High	Medium	MID-035, MID-081, MID-044	Encrypt/tunnel traffic; use OPC UA/TLS, SNMPv3, disable HTTP.
Modbus master/gateway	TID-407	Missing Message Replay Protection	High	Medium	MID-036, MID-037, MID-034	Add nonces/timestamps or wrap in authenticated tunnel.
Web management UI login	TID-311	Default Credentials	Medium	High	MID-043, MID-018	Force credential change on first login; unique per-device secrets.
Web management UI login	TID-314	Brute-Force Password Guessing	Medium	High	MID-046, MID-045, MID-049	Lockout/backoff, MFA, strong password policy.
OPC UA / HTTPS / cloud TLS	TID-316	Incorrect Certificate Verification	Medium	High	MID-027, MID-044, MID-035	Enforce cert validation, pin CA, strong TLS.
Wi-Fi / 802.15.4 / BLE radios	TID-411	Weak/Insecure Cryptographic Protocol	Medium	Medium	MID-044, MID-047, MID-035	Use 802.1X/WPA3, strong keys, secure pairing.
Firmware update subsystem	TID-211	Unauthenticated Firmware Installation	Medium	High	MID-026, MID-002, MID-041	Signed/verified firmware, hardware-backed boot auth.
Firmware update subsystem	TID-216	Firmware Update Rollbacks Allowed	Medium	Medium	MID-030, MID-026	Anti-rollback counters; reject older signed versions.
Remote firmware update trigger	TID-217	Remotely Initiated Updates Cause DoS	Medium	Medium	MID-018, MID-032, MID-038	Require admin auth + physical presence for update; availability manager.
USB-C / debug port	TID-115	Firmware/Data Extraction via Hardware Interface	Medium	High	MID-057, MID-058, MID-056	Disable debug ports, readout protection, restrict removable media.
Config import/export (DPKG)	TID-328	Hardcoded/Embedded Credentials	Medium	High	MID-028, MID-049, MID-054	Encrypt config at rest, hardware key storage, no plaintext secrets.
Modbus/OPC UA/HTTP parsers	TID-405	Network Stack Resource Exhaustion	Medium	High	MID-080, MID-008, MID-032	Request limits, robust parsers, watchdog/service manager.

Element	TID	Threat	Lik.	Imp.	Mitigations	Summary
ETH1/ETH2 IP forwarding + Modbus gateway	TID-412	Network Routing Capability Abuse	Medium	High	MID-083, MID-016, MID-081	Disable forwarding, ACLs, least functionality, segment.
Embedded web UI	TID-322	Cross Site Request Forgery (CSRF)	Medium	Medium	MID-074, MID-073	Anti-CSRF tokens, secure session management.
On-device logs	TID-226	Device Leaks Security Information in Logs	Low	Medium	MID-084, MID-085	Redact secrets, export logs off-device (syslog).

4. MITRE ATT&CK for ICS

Tactic	Technique ID	Technique	Applicability	Related EMB3D
Initial Access	T0883	Internet Accessible Device	Cloud-connected PAS600 with exposed web/Modbus may be internet-reachable.	TID-406, TID-310
Initial Access	T0860	Wireless Compromise	Access via Wi-Fi AP commissioning, BLE, or 802.15.4 join abuse.	TID-411, TID-407
Initial Access	T0812	Default Credentials	Default/unchanged web credentials grant management access.	TID-311, TID-314
Initial Access	T0822	External Remote Services	EPC/cloud/remote access services provide entry.	TID-310, TID-316
Execution	T0871	Execution through API	Web/OPC UA/EPC APIs invoke config and control functions.	TID-411, TID-322
Persistence	T0857	System Firmware	Malicious firmware via USB/EPC persists on gateway.	TID-211, TID-213, TID-216
Evasion	T0856	Spoof Reporting Message	Gateway can be made to publish falsified energy/telemetry to cloud/SCADA.	TID-408, TID-407
Discovery	T0846	Remote System Discovery	DPWS/discovery and Modbus enumeration reveal downstream devices.	TID-401, TID-406
Collection	T0882	Theft of Operational Information	Energy/metering/config data exfiltrated from gateway and cloud path.	TID-408, TID-226
Lateral Movement	T0866	Exploitation of Remote Services	Pivot via Modbus gateway/IP forwarding between OT/IT subnets.	TID-412, TID-405
Command and Control	T0869	Standard Application Layer Protocol	HTTPS/SFTP cloud channel abused for C2/exfil blending.	TID-412, TID-316
Inhibit Response Function	T0814	Denial of Service	Resource exhaustion or forced firmware-update mode denies gateway service.	TID-405, TID-217
Inhibit Response Function	T0838	Modify Alarm Settings	Alter thresholds/notifications (HeatTag, level 1/2) to hide unsafe conditions.	TID-406, TID-411
Inhibit Response Function	T0878	Alarm Suppression	Suppress notifications/emails so operators miss thermal/energy anomalies.	TID-406
Impair Process Control	T0855	Unauthorized Command Message	Unauthorized Modbus writes to downstream breakers/relays (e.g., PowerTag Control, MasterPact).	TID-406, TID-407
Impact	T0832	Manipulation of View	Falsify displayed/published measurements to operators.	TID-408, TID-407
Impact	T0829	Loss of View	Gateway outage removes visibility of all downstream devices.	TID-405, TID-217

5. Attify IoT Reverse-Engineering / Attack Surface

Domain	Vector	Technique	Finding / Hypothesis	Related EMB3D

Domain	Vector	Technique	Finding / Hypothesis	Related EMB3D
Hardware / Device Teardown	Debug/test interface discovery	UART/JTAG/SWD probing, logic analyzer, root shell	PCB likely exposes UART/test pads; JTAG status unconfirmed - could yield root/firmware.	TID-115, TID-119
Hardware / Device Teardown	Chip-off / flash extraction	SPI/NAND dump via flashrom/CH341A	External flash may be dumped to extract firmware, TLS keys, config secrets.	TID-108, TID-328
Firmware Analysis	Firmware acquisition & unpacking	Capture .sps2/eIO update files, binwalk/squashfs extract	Update images (EPC/USB) obtainable; unpack to review services and secrets.	TID-215, TID-301
Firmware Analysis	Secret & credential hunting	Entropy/grep for keys, certs, DPKG config	Exported DPKG config and firmware may embed default creds/private keys.	TID-328, TID-329, TID-226
Firmware Analysis	Update/boot chain analysis	Verify signing, secure boot, rollback checks	Secure-boot and anti-rollback strength unconfirmed; potential downgrade/injection.	TID-201, TID-213, TID-216
Radio / Wireless	Wi-Fi + BLE	Capture/crack WPA2 PSK, BLE GATT enumeration, rogue AP	AP-mode commissioning and BLE pairing exploitable for access.	TID-408, TID-411, TID-407
Radio / Wireless	Zigbee / 802.15.4	Join/pairing abuse, key capture, replay via SDR	Wireless sensor join sequence may allow rogue device/replay of telemetry.	TID-407, TID-411
Network Services	ICS/OT protocol testing	Modbus/502 & OPC UA/EtherNet-IP probing, unauthorized command, fuzzing	Unauthenticated Modbus gateway allows read/write and virtual-ID enumeration; fuzz for DoS.	TID-406, TID-405
Network Services	Cleartext & MitM	Traffic capture, ARP redirect, TLS downgrade	Modbus/SNMP cleartext and cert-validation gaps enable interception.	TID-408, TID-316
Web / Mobile / Cloud	Embedded management web UI	Auth bypass, CSRF, XSS, session token analysis, brute force	Web UI with default-password flow; test lockout, CSRF tokens, session security.	TID-311, TID-314, TID-322, TID-321
Web / Mobile / Cloud	Cloud API / EPC mobile app	APK reverse engineering, mutual-auth check, topic/authz abuse	EcoStruxure mobile/cloud provisioning may leak secrets or allow device impersonation.	TID-316, TID-412, TID-328

6. ISA/IEC 62443 Requirements Mapping

6.1 62443-4-2 Component Requirements

Req ID	Name	Design Mitigation	Addresses
CR 1.1 / CR 1.2	Human user & device/process identification and authentication	Authenticate all web/OPC UA/EPC users and downstream device sessions; extend auth to Modbus where feasible via gateway policy.	TID-406, TID-311
CR 1.5	Authenticator management (no default/hardcoded)	Force change of default password on first use; unique per-device secrets; no hardcoded keys in firmware/DPKG.	TID-311, TID-328
CR 1.7 / CR 1.11	Password strength & unsuccessful login attempts	Configurable password policy; lockout/backoff and MFA on management interfaces.	TID-314
CR 1.9	Strength of public key authentication	Enforce certificate validation for OPC UA/HTTPS/cloud; hardware-backed private-key storage.	TID-316, TID-411
CR 2.1	Authorization enforcement (RBAC least privilege)	Enforce Administrator/Viewer least-privilege on every function including firmware/config.	TID-217, TID-322

Req ID	Name	Design Mitigation	Addresses
CR 2.13 / EDR 2.13	Use of physical diagnostic and test interfaces	Disable/lock UART/JTAG and control USB config import; require authentication for local update.	TID-115, TID-211
CR 3.1	Communication integrity	Integrity-protect Modbus via authenticated tunnels; use OPC UA/TLS and signed messages.	TID-407, TID-406
CR 3.5	Input validation	Validate Modbus/OPC UA/HTTP inputs; robust parsers to prevent exhaustion/injection.	TID-405, TID-322
CR 3.4 / EDR 3.10 / EDR 3.14	Software integrity, updates & boot integrity	Signed firmware, verified secure boot, anti-rollback for .sps2/eIO images.	TID-211, TID-213, TID-216
EDR 3.11	Physical tamper resistance and detection	Tamper evidence and readout protection to resist chip-off/flash extraction.	TID-108, TID-115
CR 4.1 / CR 4.3	Information confidentiality & use of cryptography	Encrypt telemetry in transit (TLS/SFTP), encrypt config/keys at rest, validated crypto.	TID-408, TID-328
CR 5.1 / CR 5.2	Network segmentation & zone boundary protection	Disable ETH1/ETH2 IP forwarding by default; restrict gateway routing; deny-by-default ACLs.	TID-412
CR 7.1 / CR 7.2	DoS protection & resource management	Request rate limits, connection caps (10 clients), watchdog to survive floods/update triggers.	TID-405, TID-217
CR 7.7	Least functionality	Disable unused services (FTP, SNMP v1/2c, DPWS, EtherNet/IP, HTTP) by default.	TID-401, TID-408

6.2 62443-3-3 System Requirements

Req ID	Name	System Control
SR 1.1 / SR 1.2	User & device authentication	Authenticate all human and device access to the Panel Server across ETH/Wi-Fi/serial.
SR 1.5	Authenticator management	Eliminate default credentials system-wide; manage keys/certs lifecycle.
SR 1.6 / SR 2.2	Wireless access & use control	Authenticate/authorize Wi-Fi/BLE/802.15.4; disable AP commissioning after setup.
SR 1.11	Unsuccessful login attempts	Enforce lockout on management logins.
SR 3.1 / SR 4.1	Communication integrity & confidentiality	Wrap Modbus in encrypted conduits; use TLS for web/OPC UA/cloud.
SR 5.1 / SR 5.2	Network segmentation & boundary protection	Place gateway on a controlled conduit between OT and IT; deny-by-default.
SR 6.2	Continuous monitoring	Export logs to SIEM; monitor Modbus/OPC UA anomalies and login failures.
SR 7.1 / SR 7.2	DoS protection & resource management	Protect essential publication/gateway functions from exhaustion.
SR 7.3 / SR 7.4	Backup & recovery	Backup DPKG config; recover to known-good firmware/config.
SR 7.6 / SR 7.7	Security config & least functionality	Harden per Schneider cybersecurity guide; disable unused ports/services.

6.3 62443-4-1 Secure Development Lifecycle

Practice	Name	Recommendation
SR-2	Product threat model	Maintain a threat model covering gateway routing, RF, cloud, and firmware paths.
SD-4	Secure by design	Default-deny services, forwarding off by default, attack-surface reduction.
SI-2	Secure coding / implementation	Memory-safe parsing of Modbus/OPC UA/HTTP; avoid injection/overflow.
SVV-3/SVV-4	Vulnerability & penetration/fuzz testing	Fuzz Modbus/OPC UA/web; pen-test RF join and update chains.
SM-9	SBOM / third-party component management	Maintain SBOM (Wi-Fi/BLE/Zigbee stacks, TLS libs) and track CVEs.

Practice	Name	Recommendation
DM-1..6	Management of security-related issues	Operate PSIRT/vuln handling; publish advisories for PAS600.
SUM-1..5	Security update management	Signed, anti-rollback updates; timely patch delivery via EPC/cloud.
SG-3	Security guidelines	Provide hardening/decommissioning guidance (disable services, wipe config).

7. ISA-TR84.00.09 Safety / Hazard / Consequence

Applicable: Yes - SIS/SIF: The PAS600 is NOT a Safety Instrumented System or SIF logic solver - it performs no SIL-rated protective function and its downstream elements are energy/thermal sensors and metering. However, it functions as a monitoring, alarming and notification concentrator (HeatTag thermal detection, Acti9 Active, PowerTag) that operators rely on as an administrative/awareness protection layer (a non-SIS IPL). Under ISA-TR84.00.09, cyber manipulation that suppresses alarms or falsifies telemetry can defeat this awareness layer and delay response to a developing hazard (e.g., electrical overheating). ISA-84 consequence/CRA analysis is therefore included for loss-of-view and masked-thermal-event scenarios.

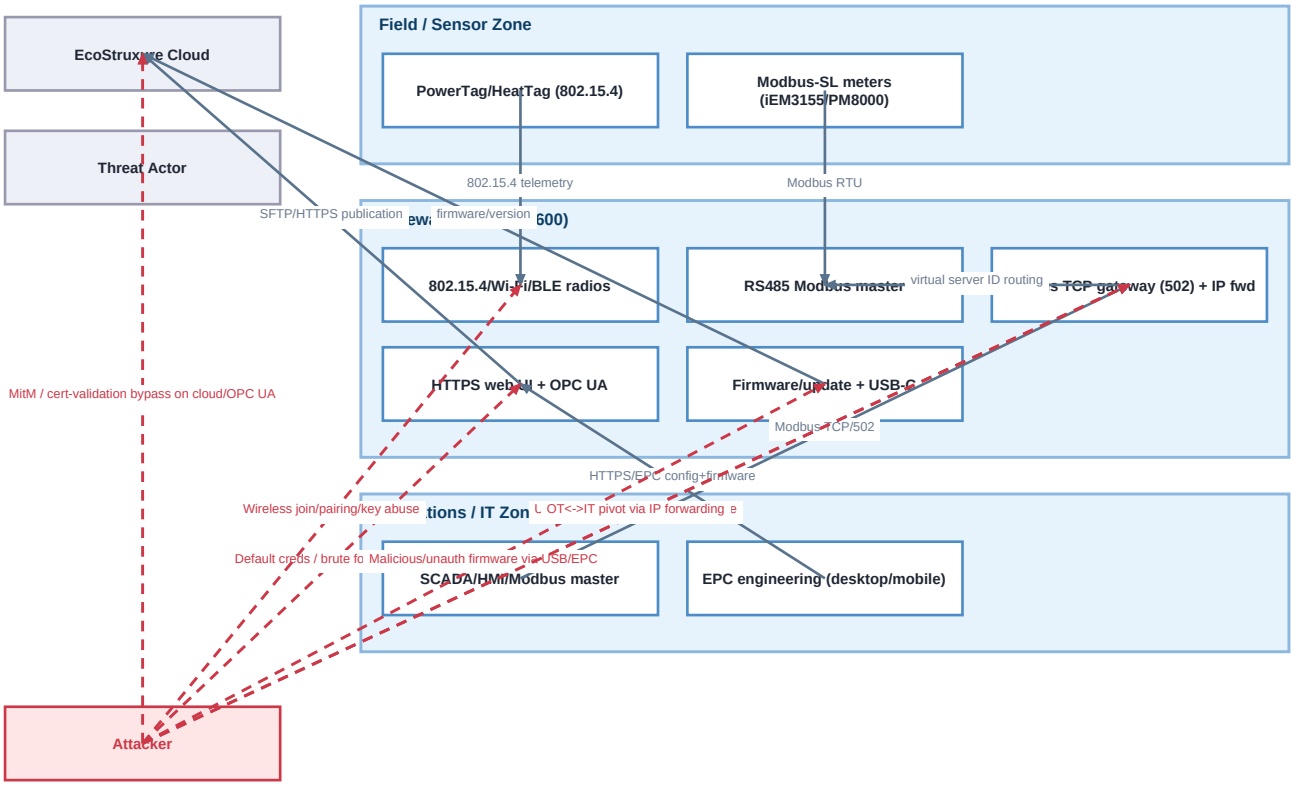
Scenario	Attack Path	Consequence	Severity	Defeats IPLs	Countermeasures
Masked electrical overheating: attacker suppresses HeatTag thermal alarms/notifications so an overheating connection is not acted upon.	T0860/T0812 (wireless/default-cred access) -> TID-406 unauthorized Modbus/config write -> T0838 Modify Alarm Settings -> T0878 Alarm Suppression -> T0829 Loss of View	Undetected thermal runaway in switchgear leading to electrical fire / equipment damage before manual intervention.	Serious	Yes	Independent hardwired thermal trip; alarm integrity/authentication; monitor for alarm-config changes; off-device log export; MFA on management.
Falsified energy/telemetry: gateway publishes spoofed measurements causing wrong operational/load decisions.	TID-408/TID-407 (cleartext/replay) -> T0830 AiTM -> T0856 Spoof Reporting Message -> T0832 Manipulation of View	Operators make incorrect load-shedding/maintenance decisions; potential overload of unprotected circuit.	Minor	Yes	TLS/OPC UA integrity, cross-check independent meters, anomaly detection on published data.
Gateway denial-of-service during a real event: forced firmware-update mode or resource exhaustion removes all downstream visibility.	T0822 remote access -> TID-217/TID-405 -> T0800 Activate Firmware Update Mode / T0814 DoS -> T0829 Loss of View	Loss of monitoring/notification during a concurrent electrical fault, delaying response.	Serious	Yes	Require admin+physical presence for update, rate limiting, redundant monitoring path, watchdog, availability manager.
Unauthorized command to controllable field devices (PowerTag Control / MasterPact MTZ) via Modbus write.	T0846 discovery -> TID-406 -> T0855 Unauthorized Command Message -> T0831 Manipulation of Control	Unexpected breaker operation / load control causing outage or unsafe switching.	Major	Yes	Read-only gateway policy, disable control writes, authenticate/segment Modbus conduit, deny-by-default ACL.

8. Risk Register

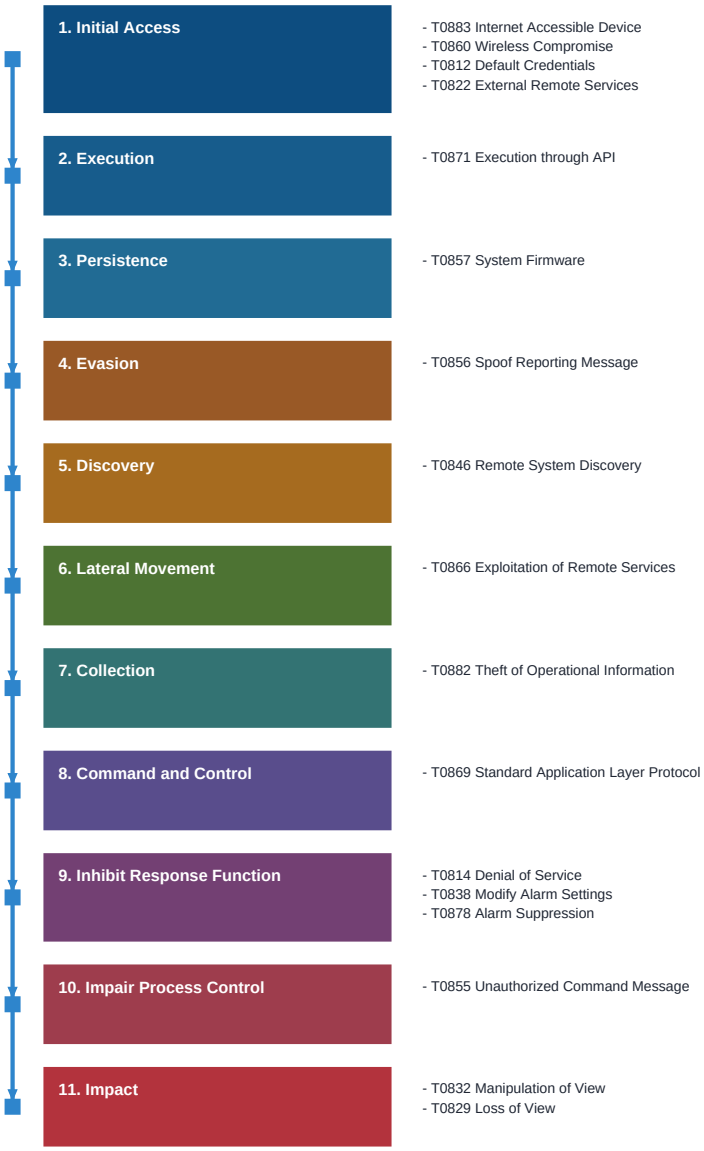
ID	Risk	Threats	ATT&CK	L	I	Level	Recommendation	Requirements
R1	Unauthenticated Modbus TCP gateway allows read/write and unauthorized commands to downstream devices.	TID-406, TID-407	T0855, T0846	H	H	Critical	Restrict Modbus via deny-by-default ACL/firewall, set gateway read-only, wrap in authenticated/encrypted conduit, disable control writes.	CR 3.1, CR 1.2, SR 5.2, SR 3.1
R2	Default/weak web credentials with insufficient lockout enable full management takeover.	TID-311, TID-314	T0812, T0859	M	H	High	Force password change on first login, enforce policy + lockout, add MFA, no hardcoded secrets.	CR 1.5, CR 1.7, CR 1.11, SR 1.5

ID	Risk	Threats	ATT&CK	L	I	Level	Recommendation	Requirements
R3	Cleartext telemetry and weak cert validation permit interception/MitM and telemetry spoofing.	TID-408, TID-316, TID-407	T0830, T0856, T0832	M	H	High	Enforce TLS/OPC UA with cert validation, SNMPv3, disable HTTP, encrypted cloud publication.	CR 3.1, CR 4.1, CR 1.9, SR 4.1
R4	Firmware update path (USB/EPC) with weak signing/rollback allows malicious/persistent firmware.	TID-211, TID-213, TID-216	T0857, T0800	M	H	High	Signed firmware, verified secure boot, anti-rollback, admin+physical-presence to update.	CR 3.4, EDR 3.10, EDR 3.14
R5	Gateway IP forwarding / virtual-server routing enables OT<->IT pivot.	TID-412	T0866, T0885	M	H	High	Disable IP forwarding by default, strict ACLs, segment ETH1/ETH2, least functionality.	CR 5.1, CR 5.2, SR 5.1
R6	Wireless (Wi-Fi/BLE/802.15.4) join/pairing/key abuse grants access or rogue-sensor injection.	TID-411, TID-407	T0860, T0887	M	M	High	Disable AP commissioning after setup, WPA3/802.1X, strong join keys, secure BLE pairing.	CR 1.6, CR 2.2, SR 1.6, SR 2.2
R7	Alarm/notification suppression hides thermal/energy hazards (HeatTag).	TID-406	T0838, T0878, T0829	M	H	High	Protect alarm config integrity, log/alert on threshold changes, independent hardwired thermal protection.	CR 2.1, SR 6.2, SR 3.1
R8	Resource exhaustion / forced update mode causes loss of view for all downstream devices.	TID-405, TID-217	T0814, T0800	M	M	Medium	Rate limiting, connection caps, watchdog, availability manager, redundant monitoring.	CR 7.1, CR 7.2, SR 7.1
R9	Physical extraction of firmware/secrets via USB, debug port, or chip-off.	TID-115, TID-108, TID-328	T0847, T0862	L	H	Medium	Disable debug ports, readout protection, encrypt config/keys at rest, tamper detection.	CR 2.13, EDR 2.13, EDR 3.11, CR 4.1
R10	Web UI application flaws (CSRF/XSS/session hijack) allow config/credential change.	TID-322, TID-321	T0871	M	M	Medium	Anti-CSRF tokens, output encoding, secure session cookies, input validation.	CR 3.5, CR 2.5, SR 3.8

9. Threat Model Diagram



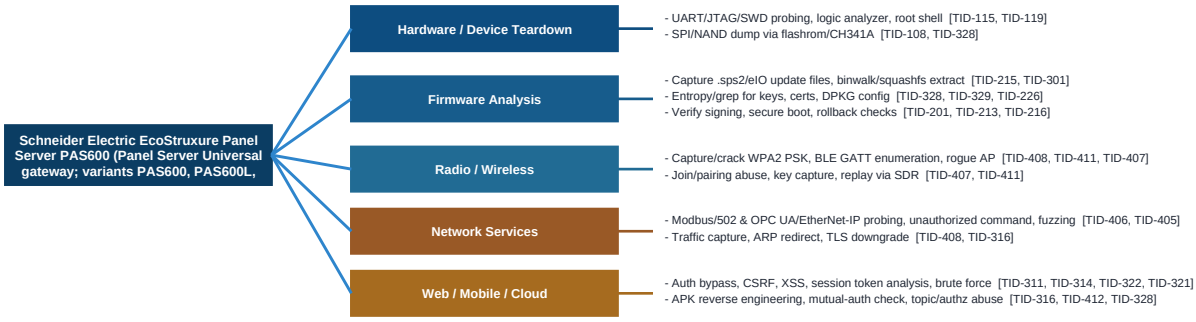
10. ATT&CK for ICS Kill Chain



11. SANS ICS Cyber Kill Chain



12. Attack Mind Map



Assumptions

- Exact SoC/MCU, memory part numbers, and presence/state of UART/JTAG/SWD debug ports are not legible in the OCR-degraded DOCA0172EN-20 manual and are assumed based on device class.
- Firmware is assumed to be an embedded Linux-class image (.sps2/eIO); secure-boot and anti-rollback strength are unconfirmed.
- Modbus TCP/RTU is assumed unauthenticated/cleartext per protocol defaults; gateway virtual-server-ID routing confirmed from artifacts.
- Default password / first-login reset flow inferred from 'Reset Password'/'default password' references; exact default not disclosed.
- Observed firmware versions 002.003.000 and 003.000.000 taken from ingested web-UI excerpt (PAS800L/PAS600).
- No public CVEs were provided in artifacts; risk ratings reflect design exposure, not a specific known vulnerability.
- OPC UA, EtherNet/IP, SNMP, FTP/FTPS, DPWS availability varies by model/config; assumed present where

referenced in the manual.

- PAS600 is treated as a non-SIS monitoring/gateway component; ISA-84 applied only to its role as an awareness/notification protection layer.